

VANGUARD IT AUDIT GROUP S.R.L.

PAPEL DE TRABAJO · ENTIDAD EVALUADA: FINANCIERA CRÉDITO FÁCIL S.A.

Cuestionario de Evaluación  
del Ambiente de Control

CEAC — 30 preguntas · 9 dimensiones

|                          |                                                                                                         |
|--------------------------|---------------------------------------------------------------------------------------------------------|
| Referencia del papel     | CEAC-2026-VAN-01                                                                                        |
| Entidad evaluada         | Financiera Crédito Fácil S.A.                                                                           |
| Alcance                  | Ambiente de control de Tecnología de la Información — procesos P1, P2 y P3 y dependencias transversales |
| Responsable entrevistado | C.P. Alberto Dorigatthi — Jefe de la División Liquidación de Créditos, con participación del CISO       |
| Auditor responsable      | Luciano Agustín Donnet — Auditor Senior, Vanguard IT Audit Group S.R.L.                                 |
| Fecha de aplicación      | 02 de julio de 2026                                                                                     |
| Marcos de referencia     | COSO 2013 · COBIT 2019 · ISO/IEC 27002:2022 · Normas IIA · SIGEN · BCRA Com. «A» 7777                   |
| Resultado consolidado    | 23 S · 5 P · 0 N · 0 N/A · 2 N/V = 76,67%                                                               |

## 1. Objeto, alcance y metodología del instrumento

El presente cuestionario constituye el instrumento formal de evaluación del ambiente de control de Tecnología de la Información de Financiera Crédito Fácil S.A. Su aplicación tiene por objeto determinar el **nivel de confianza** que el auditor puede depositar en el sistema de control interno de la entidad y, a partir de él, calibrar la naturaleza, la oportunidad y la extensión de las pruebas sustantivas del encargo.

El instrumento consta de **30 preguntas distribuidas en 9 dimensiones**, construidas sobre los componentes del marco COSO 2013 y complementadas con los procesos de gobierno de COBIT 2019, los controles organizacionales y de personas de ISO/IEC 27002:2022 y las exigencias de gobierno de la continuidad de la Comunicación «A» 7777 del BCRA.

### 1.1 Escala de calificación

| Sigla | Calificación     | Criterio de asignación                                                                                                    |
|-------|------------------|---------------------------------------------------------------------------------------------------------------------------|
| S     | Satisfactorio    | El control existe, está formalizado y opera consistentemente. Se obtuvo evidencia suficiente que lo respalda.             |
| P     | Parcial          | El control existe pero presenta deficiencias de diseño, de documentación o de aplicación que limitan su efectividad.      |
| N     | No satisfactorio | El control no existe o no opera.                                                                                          |
| N/A   | No aplica        | El control no resulta aplicable al alcance o a la naturaleza de la entidad.                                               |
| N/V   | No verificado    | No se obtuvo evidencia suficiente para emitir una calificación. Constituye limitación al alcance, no deficiencia probada. |

### 1.2 Método de aplicación

- **Entrevista estructurada** con el responsable designado por la entidad y participación del Departamento de Seguridad de la Información.
- **Verificación documental** de cada respuesta: ninguna pregunta se califica como Satisfactorio sobre la sola manifestación del entrevistado.
- **Registro del hallazgo**, que consigna la situación efectivamente constatada, con independencia de que resulte favorable o desfavorable.
- **Revisión de segundo nivel** por el Comité Técnico de Calidad de la firma auditora, previa a la determinación del nivel de confianza.

### 1.3 Fórmula de determinación del nivel de confianza

#### Cálculo

Porcentaje de controles satisfactorios =  $S / \text{total de controles aplicables evaluados} \times 100$ . Los ítems calificados como Parcial no computan como satisfactorios. Los ítems No Verificado permanecen en el denominador, por representar una limitación de evidencia que afecta la confianza depositada en el ambiente de control.

## 2. Cuestionario aplicado

### Dimensión A — Integridad y valores éticos

| Pregunta 1 · Código de ética formalizado y comunicado | S                                                                                                                                                                                                                              |
|-------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Orientación                                           | Determinar si la entidad cuenta con un código de ética aprobado por el órgano de gobierno, difundido al personal y con constancia de aceptación.                                                                               |
| Marco de referencia                                   | COSO 2013 CC1.1 · ISO/IEC 27002:2022, control 6.2                                                                                                                                                                              |
| Evidencia obtenida                                    | Código de Ética y Conducta aprobado por Acta de Directorio N.º 118 del 14/03/2024. Registro de aceptación firmado por el 96% de la dotación.                                                                                   |
| Hallazgo                                              | El código existe, está aprobado formalmente y su aceptación se encuentra documentada para la casi totalidad del personal. El 4% restante corresponde a incorporaciones del último mes, dentro del plazo de inducción previsto. |

| Pregunta 2 · Regulación del uso aceptable de sistemas, datos y credenciales | P                                                                                                                                                                                                                                                                                                                                      |
|-----------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Orientación                                                                 | Verificar si el marco normativo interno regula el uso aceptable de los recursos tecnológicos y alcanza a la totalidad de los entornos y procesos.                                                                                                                                                                                      |
| Marco de referencia                                                         | COSO 2013 CC1.1 · ISO/IEC 27002:2022, controles 5.10 y 6.2                                                                                                                                                                                                                                                                             |
| Evidencia obtenida                                                          | Código de Ética, capítulo 4, y Política de Seguridad de la Información, secciones 6 y 7, con capítulo de trabajo remoto incorporado en 2024.                                                                                                                                                                                           |
| Hallazgo                                                                    | El marco regula el uso aceptable de sistemas, datos y credenciales e incorpora un capítulo de trabajo remoto. Sin embargo, no extiende ese marco a los recursos del entorno de contingencia — sitio alternativo y cuentas de acceso de emergencia — ni alcanza a los procesos P4 y P5, que carecen de plan de continuidad documentado. |

| Pregunta 3 · Compromiso de la Dirección mediante asignación de recursos | S                                                                                                                                                                                                                                                                                            |
|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Orientación                                                             | Evaluar si la Alta Dirección respalda el ambiente de control mediante la aprobación de partidas presupuestarias destinadas a seguridad y continuidad.                                                                                                                                        |
| Marco de referencia                                                     | COSO 2013 CC1.2 · COBIT 2019 EDM01                                                                                                                                                                                                                                                           |
| Evidencia obtenida                                                      | Presupuesto anual de TI ejercicio 2026, con partida específica de resiliencia operativa aprobada por Acta del Comité de Gobierno de Tecnología del 05/12/2025.                                                                                                                               |
| Hallazgo                                                                | Se acredita la aprobación de partidas presupuestarias destinadas a resiliencia operativa. La evidencia alcanza a la aprobación del marco y a la asignación de recursos; no se extiende a la ejecución efectiva de las actividades financiadas, que se evalúa en las dimensiones específicas. |

| Pregunta 4 · Canales de reporte de desvíos éticos | S |
|---------------------------------------------------|---|
|---------------------------------------------------|---|

|                            |                                                                                                                                                                      |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Orientación</b>         | Comprobar la existencia de mecanismos accesibles y confidenciales para reportar apartamientos del código de ética.                                                   |
| <b>Marco de referencia</b> | COSO 2013 CC1.5 · ISO/IEC 27002:2022, control 6.8                                                                                                                    |
| <b>Evidencia obtenida</b>  | Procedimiento PR-ETI-02 y canal de integridad con buzón de correo dedicado y línea telefónica. Registro de tres reportes tratados en el período, con acta de cierre. |
| <b>Hallazgo</b>            | El canal existe, es de acceso directo, preserva la confidencialidad del reportante y registra tratamiento documentado de los casos recibidos.                        |

## Dimensión B — Competencia del personal de TI

|                                                                            |                                                                                                                                                                                   |
|----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 5 · Perfiles de competencia definidos para los roles de TI</b> | <b>S</b>                                                                                                                                                                          |
| <b>Orientación</b>                                                         | Verificar que los roles técnicos cuenten con perfiles de competencia formalmente definidos, incluidos los roles de contingencia.                                                  |
| <b>Marco de referencia</b>                                                 | COSO 2013 CC1.4 · ISO/IEC 27002:2022, control 6.3                                                                                                                                 |
| <b>Evidencia obtenida</b>                                                  | Manual de Misiones y Funciones, capítulo TI, con descripción de los 11 roles técnicos, incluidos los asignados a la operación del sitio alternativo.                              |
| <b>Hallazgo</b>                                                            | La totalidad de los roles técnicos cuenta con perfil de competencia definido, con requisitos de formación y experiencia. Los roles de operación del Warm Site están comprendidos. |

|                                                                     |                                                                                                                       |
|---------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 6 · Plan de capacitación técnica del personal de TI</b> | <b>S</b>                                                                                                              |
| <b>Orientación</b>                                                  | Determinar si existe un plan de capacitación formalizado y ejecutado para el personal técnico.                        |
| <b>Marco de referencia</b>                                          | COSO 2013 CC1.4 · ISO/IEC 27002:2022, control 6.3                                                                     |
| <b>Evidencia obtenida</b>                                           | Plan Anual de Capacitación 2025-2026 y registros de asistencia. Promedio de 32 horas anuales por profesional de TI.   |
| <b>Hallazgo</b>                                                     | El plan existe, está aprobado y registra ejecución verificable, con cobertura sobre la totalidad del plantel técnico. |

|                                                                            |                                                                                                                             |
|----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 7 · Evaluación periódica de desempeño del personal técnico</b> | <b>S</b>                                                                                                                    |
| <b>Orientación</b>                                                         | Comprobar la existencia de un ciclo formal de evaluación de desempeño aplicado al personal de TI.                           |
| <b>Marco de referencia</b>                                                 | COSO 2013 CC1.5 · COBIT 2019 APO07                                                                                          |
| <b>Evidencia obtenida</b>                                                  | Legajos de evaluación del ciclo 2025, con formulario firmado por evaluador y evaluado para la totalidad del personal de TI. |
| <b>Hallazgo</b>                                                            | El ciclo de evaluación se aplica anualmente, se encuentra documentado y sus resultados alimentan el plan de capacitación.   |

|                                                                              |                                                                                                                                                     |
|------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 8 · Cobertura de roles críticos y respaldo de personal clave</b> | <b>S</b>                                                                                                                                            |
| <b>Orientación</b>                                                           | Evaluar si los roles técnicos críticos cuentan con personal de respaldo designado que evite la dependencia de una única persona.                    |
| <b>Marco de referencia</b>                                                   | COBIT 2019 APO07 · ISO/IEC 27002:2022, control 5.2                                                                                                  |
| <b>Evidencia obtenida</b>                                                    | Matriz de respaldo de roles críticos, con titular y suplente designados para administración del Core, del Motor Batch y del sistema de identidades. |
| <b>Hallazgo</b>                                                              | Los roles críticos cuentan con suplente formalmente designado. No se identificaron funciones concentradas en una única persona sin respaldo.        |

## Dimensión C — Filosofía y estilo operativo de la dirección

|                                                                                           |                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 9 · Política de Seguridad de la Información aprobada, vigente y difundida</b> | <b>P</b>                                                                                                                                                                                                                                                                                                                                                                 |
| <b>Orientación</b>                                                                        | Verificar que la Política de Seguridad esté aprobada por la Alta Dirección, vigente conforme a su ciclo de revisión y activamente difundida.                                                                                                                                                                                                                             |
| <b>Marco de referencia</b>                                                                | COSO 2013 CC1.1 · ISO/IEC 27002:2022, control 5.1 · BCRA Com. «A» 7777                                                                                                                                                                                                                                                                                                   |
| <b>Evidencia obtenida</b>                                                                 | Política de Seguridad de la Información v3.1, aprobada por Acta de Directorio del 28/04/2025. Publicación en intranet corporativa.                                                                                                                                                                                                                                       |
| <b>Hallazgo</b>                                                                           | La Alta Dirección formalizó su compromiso mediante la aprobación de la política, pero el cuerpo normativo registra 14 meses sin revisión ni ratificación formal del Directorio, en desvío del ciclo anual exigido. La difusión es pasiva: el documento está disponible en la intranet, sin campañas activas ni registro de comprensión por parte del personal operativo. |

|                                                                           |                                                                                                                                                           |
|---------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 10 · Actitud de la Dirección frente al riesgo tecnológico</b> | <b>S</b>                                                                                                                                                  |
| <b>Orientación</b>                                                        | Evaluar si la Dirección considera el riesgo tecnológico en sus decisiones y asigna prioridad a su tratamiento.                                            |
| <b>Marco de referencia</b>                                                | COSO 2013 CC1.2 · COBIT 2019 EDM03                                                                                                                        |
| <b>Evidencia obtenida</b>                                                 | Actas del Comité de Gobierno de Tecnología de los ejercicios 2025 y 2026, con tratamiento del riesgo tecnológico como punto permanente del orden del día. |
| <b>Hallazgo</b>                                                           | El riesgo tecnológico integra la agenda regular del órgano de gobierno y se acredita la aprobación de partidas destinadas a su mitigación.                |

|                                                                                       |                                                                                                                  |
|---------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 11 · Participación de la Dirección en las decisiones relevantes de TI</b> | <b>S</b>                                                                                                         |
| <b>Orientación</b>                                                                    | Comprobar que las decisiones tecnológicas de impacto significativo requieren intervención del nivel de gobierno. |
| <b>Marco de referencia</b>                                                            | COBIT 2019 EDM01 · COSO 2013 CC1.2                                                                               |

|                           |                                                                                                                                                 |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Evidencia obtenida</b> | Reglamento del Comité de Gobierno de Tecnología, artículo 6, y actas de aprobación de las tres inversiones tecnológicas relevantes del período. |
| <b>Hallazgo</b>           | Las decisiones de arquitectura e inversión tecnológica se elevan al Comité y quedan documentadas en acta.                                       |

## Dimensión D — Estructura organizacional y responsabilidades

|                                                                                |                                                                                                                                        |
|--------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 12 · Organigrama vigente y ubicación jerárquica del área de TI</b> | <b>S</b>                                                                                                                               |
| <b>Orientación</b>                                                             | Verificar que exista un organigrama actualizado y que la ubicación de TI preserve su independencia respecto de las áreas usuarias.     |
| <b>Marco de referencia</b>                                                     | COSO 2013 CC3.1 · COBIT 2019 APO01                                                                                                     |
| <b>Evidencia obtenida</b>                                                      | Organigrama vigente aprobado el 15/02/2026, con la Gerencia de Operaciones y Tecnología en dependencia directa de la Gerencia General. |
| <b>Hallazgo</b>                                                                | El organigrama está vigente y la ubicación de TI garantiza independencia respecto de las áreas usuarias de los sistemas.               |

|                                                           |                                                                                                                                                                   |
|-----------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 13 · Segregación de funciones formalizada</b> | <b>S</b>                                                                                                                                                          |
| <b>Orientación</b>                                        | Evaluar si la segregación de funciones está formalizada y alcanza a las operaciones sensibles.                                                                    |
| <b>Marco de referencia</b>                                | ISO/IEC 27002:2022, control 5.3 · COSO 2013 CC3.3                                                                                                                 |
| <b>Evidencia obtenida</b>                                 | Manual de Misiones y Funciones, matriz de incompatibilidades, y configuración del esquema maker-checker del Sistema de Gestión de Tesorería.                      |
| <b>Hallazgo</b>                                           | La segregación está formalizada documentalmente e implementada técnicamente en las operaciones de Tesorería mediante esquema maker-checker de doble intervención. |

|                                                                     |                                                                                                                                            |
|---------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 14 · Designación formal del CISO y línea de reporte</b> | <b>S</b>                                                                                                                                   |
| <b>Orientación</b>                                                  | Comprobar la designación formal del responsable de seguridad de la información y la independencia de su línea de reporte.                  |
| <b>Marco de referencia</b>                                          | ISO/IEC 27002:2022, control 5.2 · BCRA Com. «A» 7724                                                                                       |
| <b>Evidencia obtenida</b>                                           | Acta de designación del CISO del 09/09/2024 y organigrama, que consigna reporte directo a la Gerencia General.                             |
| <b>Hallazgo</b>                                                     | El CISO cuenta con designación formal, funciones documentadas y línea de reporte independiente de la Gerencia de Operaciones y Tecnología. |

|                                                                         |                                                                                                             |
|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 15 · Comité de Gobierno de Tecnología en funcionamiento</b> | <b>S</b>                                                                                                    |
| <b>Orientación</b>                                                      | Verificar la existencia, la composición y la periodicidad efectiva del órgano de gobierno de la tecnología. |

|                     |                                                                                                               |
|---------------------|---------------------------------------------------------------------------------------------------------------|
| Marco de referencia | COBIT 2019 EDM01 · COSO 2013 CC2.1                                                                            |
| Evidencia obtenida  | Reglamento del Comité y actas de las once sesiones celebradas entre julio de 2025 y junio de 2026.            |
| Hallazgo            | El Comité sesiona con la periodicidad establecida en su reglamento, con quórum acreditado y actas suscriptas. |

## Dimensión E — Políticas, estándares y procedimientos de TI

|                                                                            |                                                                                                                                                                                                                                                                            |
|----------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 16 · Inventario de políticas de TI y cobertura de dominios</b> | <b>P</b>                                                                                                                                                                                                                                                                   |
| Orientación                                                                | Determinar si el inventario de políticas cubre los dominios requeridos y si todas se encuentran en versión aprobada y vigente.                                                                                                                                             |
| Marco de referencia                                                        | ISO/IEC 27002:2022, control 5.1 · COBIT 2019 APO01                                                                                                                                                                                                                         |
| Evidencia obtenida                                                         | Inventario de políticas de TI al 30/06/2026, con quince documentos registrados y su estado de aprobación.                                                                                                                                                                  |
| Hallazgo                                                                   | El inventario cubre los dominios requeridos, pero la política de gestión de incidentes de ciberseguridad se encuentra en versión borrador sin aprobación del Comité, y los procedimientos aplicables a los entornos de contingencia no registran versión aprobada vigente. |

|                                                                  |                                                                                                                                               |
|------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 17 · Estándares técnicos de configuración segura</b> | <b>S</b>                                                                                                                                      |
| Orientación                                                      | Verificar la existencia de estándares de configuración segura para las plataformas críticas.                                                  |
| Marco de referencia                                              | ISO/IEC 27002:2022, control 8.9 · COBIT 2019 BAI10                                                                                            |
| Evidencia obtenida                                               | Estándares de hardening para sistema operativo de servidores, motor de base de datos y plataforma de virtualización, aprobados el 20/11/2025. |
| Hallazgo                                                         | Los estándares existen, están aprobados, se encuentran vigentes y contemplan las plataformas que soportan a los procesos modulares.           |

|                                                                       |                                                                                                                                                                                                                                   |
|-----------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 18 · Vigencia del Manual de Procedimientos Operativos</b> | <b>P</b>                                                                                                                                                                                                                          |
| Orientación                                                           | Comprobar que los procedimientos operativos se mantengan actualizados conforme al ciclo de revisión establecido.                                                                                                                  |
| Marco de referencia                                                   | ISO/IEC 27002:2022, control 5.37 · BCRA Com. «A» 7777                                                                                                                                                                             |
| Evidencia obtenida                                                    | Manual de Procedimientos Operativos, última versión registrada en diciembre de 2024, e historial de cambios.                                                                                                                      |
| Hallazgo                                                              | El Manual y las políticas asociadas presentan una desactualización superior a 18 meses frente a cambios regulatorios y de arquitectura ocurridos en el período, pese a que el ciclo formal establece revisión anual o por evento. |

## Dimensión F — Gestión de recursos humanos en TI

|                                                                                           |                                                                                                                                 |
|-------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 19 · Verificación de antecedentes en la incorporación de personal técnico</b> | <b>S</b>                                                                                                                        |
| <b>Orientación</b>                                                                        | Evaluar si el proceso de selección incluye verificación de antecedentes proporcional a la criticidad del rol.                   |
| <b>Marco de referencia</b>                                                                | ISO/IEC 27002:2022, control 6.1                                                                                                 |
| <b>Evidencia obtenida</b>                                                                 | Procedimiento de selección PR-RRHH-04 y legajos de las cinco incorporaciones de TI del período, con constancia de verificación. |
| <b>Hallazgo</b>                                                                           | La verificación de antecedentes se aplica de manera consistente y está documentada en la totalidad de los legajos revisados.    |

|                                                              |                                                                                                                                      |
|--------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 20 · Acuerdos de confidencialidad suscriptos</b> | <b>S</b>                                                                                                                             |
| <b>Orientación</b>                                           | Comprobar que el personal y los terceros con acceso a información sensible suscriban acuerdos de confidencialidad.                   |
| <b>Marco de referencia</b>                                   | ISO/IEC 27002:2022, control 6.6                                                                                                      |
| <b>Evidencia obtenida</b>                                    | Legajos del personal de TI y contratos de los proveedores críticos, con cláusula de confidencialidad suscripta.                      |
| <b>Hallazgo</b>                                              | Los acuerdos se encuentran suscriptos tanto por el personal interno como por los proveedores con acceso a información de la entidad. |

|                                                                              |                                                                                                                                               |
|------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 21 · Procedimiento de desvinculación y revocación de accesos</b> | <b>S</b>                                                                                                                                      |
| <b>Orientación</b>                                                           | Verificar que la desvinculación de personal desencadene la revocación oportuna de los accesos otorgados.                                      |
| <b>Marco de referencia</b>                                                   | ISO/IEC 27002:2022, controles 6.5 y 5.18                                                                                                      |
| <b>Evidencia obtenida</b>                                                    | Procedimiento PR-RRHH-07 e integración automatizada entre el sistema de Recursos Humanos y el sistema de gestión de identidades.              |
| <b>Hallazgo</b>                                                              | El procedimiento existe y opera de manera automatizada: la baja en Recursos Humanos dispara la revocación de accesos sin intervención manual. |

## Dimensión G — Supervisión y rendición de cuentas

|                                                                               |                                                                                                                                                                                                                                                                                                 |
|-------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 22 · Monitoreo de indicadores de TI reportados a la Dirección</b> | <b>S</b>                                                                                                                                                                                                                                                                                        |
| <b>Orientación</b>                                                            | Determinar si existe un mecanismo periódico de reporte de indicadores operativos de TI al nivel de gobierno.                                                                                                                                                                                    |
| <b>Marco de referencia</b>                                                    | COBIT 2019 MEA01 · COSO 2013 CC4.1                                                                                                                                                                                                                                                              |
| <b>Evidencia obtenida</b>                                                     | Tableros mensuales de gestión de TI de los doce meses del período y actas del Comité que registran su tratamiento.                                                                                                                                                                              |
| <b>Hallazgo</b>                                                               | El tablero mensual reporta disponibilidad de los servicios y cumplimiento de la ejecución de copias a la Gerencia General, con periodicidad sostenida. El tablero no incorpora resultados de pruebas de restauración ni el estado de cumplimiento de los objetivos de recuperación por proceso. |



| Pregunta 23 · Autoevaluación de control (CSA) y validación de sus resultados | P                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Orientación                                                                  | Evaluar si la metodología de autoevaluación de control se aplica con alcance suficiente y con validación independiente de sus resultados.                                                                                                                                                                                                                                  |
| Marco de referencia                                                          | COSO 2013 CC4.1 · Resolución SIGEN N.º 36/2011 · COBIT 2019 MEA02                                                                                                                                                                                                                                                                                                          |
| Evidencia obtenida                                                           | Metodología de CSA aprobada, cuestionarios anuales completados por los líderes de TI y planilla de resultados del ciclo 2025.                                                                                                                                                                                                                                              |
| Hallazgo                                                                     | Existe una metodología formal de autoevaluación con cuestionarios anuales a los líderes de TI, pero su ejecución es declarativa: no hay validación cruzada ni contraste con evidencia técnica. El alcance omitió el API Gateway de liquidación y la infraestructura batch de haberes, y los desvíos autodetectados no derivan en planes de acción con responsable y plazo. |

| Pregunta 24 · Función de Auditoría Interna de Sistemas | S                                                                                                                                           |
|--------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| Orientación                                            | Comprobar la existencia de una función de auditoría interna con estatuto formal y acceso irrestricto a la información.                      |
| Marco de referencia                                    | Normas IIA 1000 y 1100 · COBIT 2019 MEA02                                                                                                   |
| Evidencia obtenida                                     | Estatuto de Auditoría Interna aprobado por el Directorio el 11/06/2024, con reporte funcional al Comité de Auditoría.                       |
| Hallazgo                                               | La función cuenta con estatuto formal, independencia orgánica y acceso irrestricto a sistemas e información, conforme al estatuto aprobado. |

| Pregunta 25 · Seguimiento y cierre de observaciones de auditorías previas | N/V                                                                                                                                                                                                                                                             |
|---------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Orientación                                                               | Verificar la existencia de una matriz de seguimiento de hallazgos previos con estado de regularización actualizado.                                                                                                                                             |
| Marco de referencia                                                       | Normas IIA 2500 · Resolución SIGEN N.º 36/2011                                                                                                                                                                                                                  |
| Evidencia obtenida                                                        | No se obtuvo evidencia. El legajo de auditorías de TI anteriores fue requerido el 25/06/2026 y reiterado por escrito el 02/07/2026 sin respuesta.                                                                                                               |
| Hallazgo                                                                  | No fue posible obtener evidencia sobre el seguimiento y cierre de las observaciones de auditorías de TI anteriores, por no haberse puesto a disposición el legajo dentro del plazo del relevamiento documental. Se deja constancia de la limitación al alcance. |

## Dimensión H — Gestión del riesgo de TI

| Pregunta 26 · Metodología de gestión de riesgos de TI aprobada | S                                                                                                                       |
|----------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| Orientación                                                    | Determinar si la entidad cuenta con una metodología formal para identificar, valorar y tratar los riesgos tecnológicos. |
| Marco de referencia                                            | COBIT 2019 APO12 · COSO 2013 CC7.1                                                                                      |

|                           |                                                                                                                                                  |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Evidencia obtenida</b> | Metodología de Gestión de Riesgos de TI v2.0, aprobada por el Comité de Gobierno de Tecnología el 18/03/2025.                                    |
| <b>Hallazgo</b>           | La metodología está aprobada, define criterios de valoración de impacto y probabilidad y establece el ciclo de revisión del registro de riesgos. |

|                                                                           |                                                                                                                                                                                  |
|---------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 27 · Registro de riesgos de TI con propietarios asignados</b> | <b>S</b>                                                                                                                                                                         |
| <b>Orientación</b>                                                        | Comprobar que el registro de riesgos se encuentre actualizado, con propietario designado por riesgo y cobertura de terceros y privacidad.                                        |
| <b>Marco de referencia</b>                                                | COBIT 2019 APO12 · ISO/IEC 27002:2022, control 5.19                                                                                                                              |
| <b>Evidencia obtenida</b>                                                 | Registro corporativo de riesgos de TI al 30/06/2026, con 34 riesgos registrados, propietario asignado y fecha de última revisión.                                                |
| <b>Hallazgo</b>                                                           | El registro se encuentra actualizado, cubre riesgos asociados a proveedores críticos y a la protección de datos personales, y consigna propietario responsable para cada riesgo. |

## Dimensión I — Comunicación e información para el control

|                                                                               |                                                                                                                                 |
|-------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 28 · Canales de comunicación de políticas y responsabilidades</b> | <b>S</b>                                                                                                                        |
| <b>Orientación</b>                                                            | Evaluar si la entidad dispone de canales formales para comunicar políticas, responsabilidades y cambios normativos al personal. |
| <b>Marco de referencia</b>                                                    | COSO 2013 CC2.2 · ISO/IEC 27002:2022, control 5.1                                                                               |
| <b>Evidencia obtenida</b>                                                     | Intranet corporativa, circulares internas y registro de comunicaciones del período.                                             |
| <b>Hallazgo</b>                                                               | Los canales existen, son accesibles a la totalidad del personal y registran las comunicaciones emitidas durante el período.     |

|                                                                     |                                                                                                                                                               |
|---------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 29 · Reportes periódicos de TI al nivel de gobierno</b> | <b>S</b>                                                                                                                                                      |
| <b>Orientación</b>                                                  | Verificar que el nivel de gobierno reciba información periódica y suficiente sobre la gestión tecnológica.                                                    |
| <b>Marco de referencia</b>                                          | COBIT 2019 MEA01 · COSO 2013 CC2.3                                                                                                                            |
| <b>Evidencia obtenida</b>                                           | Informes trimestrales de gestión de TI elevados al Comité de Gobierno de Tecnología durante el período.                                                       |
| <b>Hallazgo</b>                                                     | Los reportes se emiten con la periodicidad establecida e incluyen métricas de desempeño operativo, incidentes registrados y estado de cumplimiento normativo. |

|                                                                                 |                                                                                                                |
|---------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| <b>Pregunta 30 · Medición de la efectividad del programa de concientización</b> | <b>N/V</b>                                                                                                     |
| <b>Orientación</b>                                                              | Comprobar si la entidad mide la efectividad de sus acciones de concientización en seguridad de la información. |

|                     |                                                                                                                                                                                                                                                                     |
|---------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Marco de referencia | ISO/IEC 27002:2022, control 6.3 · COSO 2013 CC2.2                                                                                                                                                                                                                   |
| Evidencia obtenida  | Registros de campañas de concientización ejecutadas. No se obtuvo evidencia de mediciones de efectividad.                                                                                                                                                           |
| Hallazgo            | Existen registros de campañas de concientización, pero no se obtuvo evidencia de medición formal de su efectividad, circunstancia atribuida por la entidad a una migración en curso de la plataforma de e-learning. Se deja constancia de la limitación al alcance. |

### 3. Consolidación de resultados

| Dimensión                                        | Total | S  | P | N | N/A | N/V | S / total |
|--------------------------------------------------|-------|----|---|---|-----|-----|-----------|
| A. Integridad y valores éticos                   | 4     | 3  | 1 | 0 | 0   | 0   | 75,0%     |
| B. Competencia del personal de TI                | 4     | 4  | 0 | 0 | 0   | 0   | 100,0%    |
| C. Filosofía y estilo operativo de la dirección  | 3     | 2  | 1 | 0 | 0   | 0   | 66,7%     |
| D. Estructura organizacional y responsabilidades | 4     | 4  | 0 | 0 | 0   | 0   | 100,0%    |
| E. Políticas, estándares y procedimientos de TI  | 3     | 1  | 2 | 0 | 0   | 0   | 33,3%     |
| F. Gestión de RR. HH. en TI                      | 3     | 3  | 0 | 0 | 0   | 0   | 100,0%    |
| G. Supervisión y rendición de cuentas            | 4     | 2  | 1 | 0 | 0   | 1   | 50,0%     |
| H. Gestión del riesgo de TI                      | 2     | 2  | 0 | 0 | 0   | 0   | 100,0%    |
| I. Comunicación e información para el control    | 3     | 2  | 0 | 0 | 0   | 1   | 66,7%     |
| Total CEAC                                       | 30    | 23 | 5 | 0 | 0   | 2   | 76,67%    |

#### 3.1 Determinación del nivel de confianza

**Cálculo:** 23 controles satisfactorios / 30 controles aplicables  $\times 100 = 76,67\%$ .

**Control de sensibilidad:** si los dos ítems No Verificado se excluyeran del denominador, el resultado sería  $23/28 = 82,14\%$ . No se adopta ese criterio, por cuanto ocultaría el efecto de la falta de evidencia sobre la confianza depositada en el ambiente de control. Ambas alternativas conducen, en todo caso, a la misma calificación.

| Nivel de confianza | Rango      | Efecto sobre la estrategia de auditoría                                                            |
|--------------------|------------|----------------------------------------------------------------------------------------------------|
| ALTO               | 75% – 100% | Pruebas de cumplimiento extensas, menor volumen de pruebas sustantivas y muestras de menor tamaño. |
| MEDIO              | 45% – 74%  | Combinación equilibrada de pruebas de cumplimiento y sustantivas.                                  |
| BAJO               | 0% – 44%   | Pruebas sustantivas extensas; no se deposita confianza en los controles.                           |

#### Resultado: 76,67% — Nivel de confianza ALTO, en el tramo inferior de la banda (75% – 100%)

El ambiente de control admite que el auditor deposite confianza en los controles existentes y privilegie las pruebas de cumplimiento sobre la revisión documental de poblaciones completas, reduciendo la extensión de las pruebas sustantivas y el tamaño de las muestras. La confianza se acota, no obstante, en las dimensiones **E (Políticas, estándares y procedimientos)** y **G (Supervisión y rendición de cuentas)**, que concentran cuatro de las cinco calificaciones Parcial y uno de los dos No Verificado, y sobre las que corresponde ampliar la verificación.

#### 3.2 Conclusión sobre el ambiente de control

El ambiente de control de Financiera Crédito Fácil S.A. presenta un **diseño de gobierno sólido en su dimensión estructural**: la ubicación de TI en el organigrama garantiza independencia, la segregación de funciones está formalizada e implementada técnicamente, el CISO cuenta con designación formal y línea de reporte propia, la revocación de accesos ante desvinculación opera de manera automatizada, y la metodología de gestión de riesgos de TI está aprobada y con propietarios asignados.

La debilidad se concentra en el **mantenimiento del cuerpo normativo y en los mecanismos de rendición de cuentas**. Las políticas existen pero envejecen sin revisión —14 meses la Política de Seguridad, más de 18 los procedimientos operativos—, en un período en el que la arquitectura de la entidad cambió por efecto de la migración digital. Las autoevaluaciones se ejecutan de manera declarativa y sin validación independiente, y no fue posible acreditar el cierre de las observaciones de auditorías anteriores.

De ello se sigue una consecuencia relevante para la planificación del encargo: el marco de continuidad de la entidad no presenta un problema de **ausencia de diseño**, sino de **mantenimiento y verificación del diseño existente**. Las pruebas deben orientarse, en consecuencia, a la vigencia documental, a la aprobación formal de los parámetros y a la evidencia de ejecución, antes que a la mera existencia de los instrumentos.

**Aplicado por:** Luciano Agustín Donnet — Auditor Senior.

**Revisión de segundo nivel:** Comité Técnico de Calidad — Vanguard IT Audit Group S.R.L.

**Conformidad del entrevistado:** C.P. Alberto Dorigatthi — Financiera Crédito Fácil S.A.

**Fecha:** 02 de julio de 2026 · Referencia CEAC-2026-VAN-01.